

Term	Definition	Source
Cyber risk	Risk of financial loss, operational disruption, or damage from the failure of the digital technologies employed for informational and/or operational functions introduced to a manufacturing system via electronic means from the unauthorized access, use, disclosure, disruption, modification, or destruction of the manufacturing system.	NIST Glossary
	Risk of financial loss, operational disruption, or damage from the failure of the digital technologies employed for informational and/or operational functions introduced to a system via electronic means from the unauthorized access, use, disclosure, disruption, modification, or destruction of the system.	FFIEC Adapted for Supervisory Purposes
D		
Dashboard	A tool that consolidates and communicates information relevant to the entity in near real-time. It is generally visual and often uses a variety of charts.	NIST SP 800-137
Data	A representation of information as stored or transmitted.	NIST Glossary
	A physical or digital representation of information processed, stored (at rest), or transmitted (in transit).	FFIEC Adapted for Supervisory Purposes
Data analytics	The systematic process of evaluating and organizing data sets to draw insights, make predictions, and reveal trends using logical analysis.	FFIEC Developed for Supervisory Purposes
Data center	A facility that houses virtual and/or physical information technology infrastructure(s) (e.g., computer, server, and networking systems and components) designed to store, process, and serve large amounts of data in support of an entity's strategic and business objectives. A data center may be a dedicated facility or an area or room that contains computer, server, and networking systems and components, and may be private or shared (e.g., a co-location facility).	FFIEC Developed for Supervisory Purposes
Data classification	Categorizing data based on its level of sensitivity (e.g., confidentiality, integrity, or availability), value, and criticality to the entity.	FFIEC Developed for Supervisory Purposes
Data communications	The transfer of data over networks using a combination of telecommunication services and network devices.	FFIEC Developed for Supervisory Purposes
Data governance	A set of processes that ensures that data assets are formally managed throughout the enterprise. A data governance model establishes authority and management and decision-making parameters related to the data produced or managed by the enterprise.	NIST Glossary
Data management	The practice of putting into place policies, procedures and best practices to ensure that data is understandable, trusted, visible, accessible and interoperable.	DHS Lexicon Terms and Definitions
	The practice of putting into place policies, procedures, and best practices to ensure that data are understandable, trusted, visible, accessible, and interoperable to ensure that user needs are met.	FFIEC Adapted for Supervisory Purposes
Database	A repository of information or data, which may or may not be a traditional relational database system.	NIST Glossary

Term	Definition	Source
	A repository of information or data organized to be accessed, managed, and updated.	FFIEC Adapted for Supervisory Purposes
Denial of service (DOS) attack	An assault on a service from a single source that floods it with so many requests that it becomes overwhelmed and is either stopped completely or operates at a significantly reduced rate.	ISACA Glossary
Device	A piece of equipment or a mechanism designed to serve a special purpose or perform a special function.	Merriam-Webster
Dirty power	A term used to describe a power line where disturbances (e.g., outages, voltage spikes, and drop-outs) occur.	A New IEC Standard on the Measurement of Power Quality Parameters
Distributed denial of service (DDOS)	A denial of service technique that uses numerous hosts to perform the attack.	NIST Glossary
Domain name	A domain name is a human-friendly name (such as “www.dhs.gov”) that is resolved (i.e., translates domain names into Internet Protocol [IP] addresses) by a network of domain name service servers to a specific IP address, which is in turn, associated with a single host (referring to a single server or server cluster).	DHS Directives System
	A unique identifier for a network address.	FFIEC Adapted for Supervisory Purposes
Domain name system (DNS)	A distributed computing system that enables access to Internet resources by user-friendly domain names rather than IP addresses, by translating domain names to IP addresses and back. Also known as domain name service (DNS).	NIST SP 800-81-2
Dynamic host configuration protocol (DHCP)	A protocol used by networked computers (clients) to obtain IP addresses and other parameters, such as the default gateway, subnet mask and IP addresses of domain name system servers from a DHCP server. The DHCP server ensures that all IP addresses are unique. IP address pool management is done by the server and not by a human network administrator.	ISACA Glossary
E		
Encryption	Any procedure used in cryptography to convert plain text into cipher text to prevent anyone but the intended recipient from reading that data.	NIST Glossary
End-of-life (EOL)	With respect to technology, a time frame usually defined by a technology vendor to describe when an asset has reached the end of its useful life cycle and when the vendor will no longer maintain and support the asset or continue to sell or license it.	FFIEC Developed for Supervisory Purposes
Enterprise architecture	The description of an enterprise’s entire set of information systems: how they are configured, how they are integrated, how they interface to the external environment at the enterprise’s boundary, how they are operated to support the enterprise mission, and how they contribute to the enterprise’s overall security posture.	NIST Glossary

Term	Definition	Source
Enterprise resource planning system	A packaged business software system that allows an enterprise to automate and integrate the majority of its business processes, share common data and practices across the entire enterprise, and produce and access information in a real-time environment.	ISACA Glossary
Event	Occurrence or change of a particular set of circumstances.	NIST Glossary
	An occurrence or change in circumstances that may affect operations. An event can be physical, cyber, or a combination of both.	FFIEC Developed for Supervisory Purposes
F		
False positive	A result that has been mistakenly identified as a problem when, in reality, the situation is normal.	ISACA Glossary
File exchange	(Also known as file sharing) A method of sending and receiving files inside the entity and with other parties through email attachments, file sharing services, and other means.	NIST Security Considerations for Exchanging Files Over the Internet
Firewall	A gateway that limits access between networks in accordance with local security policy.	NIST Glossary
Functional testing	Testing that verifies that an implementation of some function operates correctly.	NIST Glossary
G		
Gateway	An intermediate system (interface, relay) that attaches to two (or more) computer networks that have similar functions but dissimilar implementations and that enables either one-way or two-way communication between the networks.	NIST Glossary
H		
Hardening	A process to eliminate as many security risks as possible by removing all nonessential software programs, protocols, services and utilities from the system. (Referred to as system hardening)	ISACA Glossary
	A process intended to eliminate as many security risks as possible by implementing security controls (e.g., changing default passwords, enabling security settings, and protecting privileged accounts), patching vulnerabilities, turning off nonessential services, and removing all nonessential software programs, protocols, and utilities from the system.	FFIEC Adapted for Supervisory Purposes
Hardware	The physical components of an information system.	NIST Glossary
Hashing	The process of using a mathematical algorithm against data to produce a numeric value that is representative of that data.	NIST Glossary
Help desk	A service offered via telephone/Internet by an enterprise to its clients or employees that provides information, assistance and troubleshooting advice regarding software, hardware or networks.	ISACA Glossary
Hub	A common connection point for devices in a network. Hubs commonly are used to pass data from one device (or segment) to another.	NIST Glossary
Hybrid cloud	The hybrid cloud infrastructure is a composition of two or more distinct cloud infrastructures (e.g., private, community, or public) that	NIST Glossary

Term	Definition	Source
	are unique entities, but are bound together by standardized or proprietary technology that enables data and application portability (e.g., cloud bursting for load balancing between clouds).	
Hybrid-hosted-software arrangement	An agreement where software resides at both the entity (also referred to as on-premise) and on the third-party service provider's servers (e.g., software as a service).	FFIEC Developed for Supervisory Purposes
Hypervisor	The virtualization component that manages the guest operating systems (OSs) on a host and controls the flow of instructions between the guest OSs and the physical hardware.	NIST Glossary
I		
Identity and access management (IAM)	Encapsulates people, processes, and products to identify and manage the data used in an information system to authenticate users and grant or deny access rights to data and system resources.	ISACA Glossary
Incident	An occurrence that actually or potentially jeopardizes the confidentiality, integrity, or availability of a system or the information the system processes, stores, or transmits or that constitutes a violation or imminent threat of violation of security policies, security procedures, or acceptable use policies.	NIST Glossary
Incident management	The process of identifying, analyzing, and correcting disruptions to operations and preventing future recurrences. The goal of incident management is to limit the disruption and restore operations as quickly as possible.	FFIEC Developed for Supervisory Purposes
Information security	The protection of information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to provide confidentiality, integrity, and availability.	NIST Glossary
Information technology asset management (ITAM)	Refers to a set of policies and procedures that an organization uses to track, audit, and monitor the state of its IT assets, and maintain system configurations.	NIST SP 1800-5
Infrastructure	System of facilities, equipment, and services needed for the operation of an organization.	ISO 22300:2018(en)
	The physical elements, products, and services necessary to provide and maintain ongoing operations to support business activity and includes the maintenance of physical facilities.	FFIEC Adapted for Supervisory Purposes
Infrastructure as a service (IaaS)	IaaS provides entities with the ability to provision processing, storage, networks, and other fundamental computing resources where the entity is able to deploy and run software, which can include operating systems and applications. The entity does not manage or control the underlying cloud infrastructure; however, it has control over operating systems, storage, and deployed applications. Entities have the maximum flexibility to customize their cloud services and user interfaces.	NIST SP 500-316
Integrity	A property whereby data has not been altered in an unauthorized manner since it was created, transmitted or stored.	NIST Glossary

Term	Definition	Source
Interdependencies	When two or more departments, processes, functions, or third-party providers interact to successfully complete a task, business function, or process.	FFIEC Developed for Supervisory Purposes
Internet of things (IoT)	Refers to the collection of technologies that allow information to be sent to and received from physical devices (e.g., security systems, HVAC systems, intelligent personal assistants, and kitchen appliances), that were not traditionally thought of as IT assets, using the internet. These devices have the ability to send and receive data over a network without necessarily requiring human-to-human or human-to-computer interaction using embedded computing capability and network connectivity and unique identifiers (e.g., IP address).	FFIEC Developed for Supervisory Purposes
Intrusion detection system (IDS)	A security service that monitors and analyzes network or system events for the purpose of finding, and providing real-time or near real-time warning of, attempts to access system resources in an unauthorized manner.	NIST Glossary
Intrusion prevention system (IPS)	A system that can detect an intrusive activity and can also attempt to stop the activity, ideally before it reaches its targets.	NIST Glossary
IP address	A unique binary number used to identify devices on a TCP/IP network.	ISACA Glossary
IT infrastructure	A subset of infrastructure that includes hardware, network and telecommunications, software, IT environmental controls (e.g., power, cooling, and ventilation), and physical access.	FFIEC Developed for Supervisory Purposes
J		
Jailbreaking (also known as rooting)	To allow the device's owner to remove manufacturer or carrier restrictions, to gain full access to the root of the operating system and access all the features.	FFIEC Developed for Supervisory Purposes
Job scheduling	Generally an automated process to allocate system resources and execute processes based on the priority and processing resources available.	FFIEC Developed for Supervisory Purposes
L		
Latency	Time delay in processing voice packets.	NIST Glossary
	Time delay in processing voice and data packets.	FFIEC Adapted for Supervisory Purposes
License	A permission granted by competent authority to engage in a business or occupation or in an activity otherwise unlawful.	Merriam-Webster
Load balancing	Load balancers distribute HTTP requests over multiple Web servers, allowing organizations to increase the capacity of their Web site by transparently adding additional servers. Load balancers act as virtual servers, receiving all HTTP requests to the Web site. These requests are forwarded, based on the load balancer's policy, to one of the servers that hosts the Web site. The load balancer's policy attempts to ensure that each server receives a similar number of requests. Many load balancers are capable of monitoring the servers and compensating if one of the servers becomes unavailable.	NIST SP 800-44 v.2

Term	Definition	Source
	The distribution of processing (e.g., network traffic, processing requests or power) across equipment to ensure that any one device is not overwhelmed by high demand.	FFIEC Adapted for Supervisory Purposes
Local area network (LAN)	A group of computers and other devices dispersed over a relatively limited area and connected by a communications link that enables any device to interact with any other on the network.	NIST Glossary
Log	A record of events occurring within an entity's systems and networks.	NIST Glossary
Log management	The process to generate, transmit, store, analyze, and dispose of log data.	NIST Glossary
Loose coupling	An approach to designing systems so that linked components of networks, software, and services can be scaled to operate as independently as possible, in order to avoid issues with one component adversely affecting others.	FFIEC Developed for Supervisory Purposes
M		
Machine learning (ML)	The process of using an algorithm(s) to help computers learn without being explicitly programmed and identify patterns within data. Those patterns are then used to create a data model that can make predictions.	FFIEC Developed for Supervisory Purposes
Mainframe	A large, high-speed computer, especially one supporting numerous workstations or peripherals.	ISACA Glossary
Maintenance	Any act that either prevents the failure or malfunction of equipment or restores its operating capability.	NIST Glossary
Malicious code	Unwanted files or programs that can cause harm to a computer or compromise data stored on a computer. Various classifications of malicious code include viruses, worms, and Trojan horses.	DHS, CISA Security Tip (ST18-004)
Malware	A program that is inserted into a system, usually covertly, with the intent of compromising the confidentiality, integrity, or availability of the victim's data, applications, or operating system or of otherwise annoying or disrupting the victim.	NIST Glossary
Man in the middle (MitM) attack	An attack where the adversary positions himself in between the user and the system so that he can intercept and alter data traveling between them.	NIST Glossary
Masking	The process of systematically removing a field or replacing it with a value in a way that does not preserve the analytic utility of the value, such as replacing a phone number with asterisks or a randomly generated pseudonym.	NIST Glossary
Media access control (MAC)	Applied to the hardware at the factory and cannot be modified, MAC is a unique, 48-bit, hard-coded address of a physical layer device, such as an Ethernet local area network (LAN) or a wireless network card.	ISACA Glossary
Media access control (MAC) address	A unique identifier assigned to network interfaces for communications on the physical network segment.	ISACA Glossary
	A unique identifier assigned to network interfaces for communications on the physical network segment. MAC is a 48-bit,	FFIEC Adapted for Supervisory Purposes

Term	Definition	Source
	hard-coded address applied to the hardware at the factory and cannot be modified.	
Metadata	Data about data. For file systems, metadata is data that provides information about a file's contents.	NIST Glossary
	Data about data. Examples of metadata include purpose of the data, creator or owner of the data, file size, location where the data were created, and source of the data.	FFIEC Adapted for Supervisory Purposes
Microservices	A set of containers that work together to compose an application.	NIST Glossary
Mobile computing	Extends the concept of wireless computing to devices that enable new kinds of applications and expand an enterprise network to reach places in circumstances that could never have been done by other means. Mobile computing is comprised of personal digital assistants (PDAs), cellular phones, laptops and other technologies of this kind.	ISACA Glossary
Mobile device	A portable computing device that: (i) has a small form factor such that it can easily be carried by a single individual; (ii) is designed to operate without a physical connection (e.g., wirelessly transmit or receive information); (iii) possesses local, non-removable data storage; and (iv) is powered-on for extended periods of time with a self-contained power source.	NIST Glossary
Multi-factor authentication	Authentication using two or more factors to achieve authentication. Factors include: (i) something you know (e.g., password or personal identification number (PIN)); (ii) something you have (e.g., cryptographic identification device or token); or (iii) something you are (e.g., biometric).	NIST Glossary
Multi-tenancy	Design where one or more entities and their information and technology assets reside in a shared environment. The instances (tenants) are logically isolated, but physically integrated.	FFIEC Developed for Supervisory Purposes
N		
Network	A system implemented with a collection of interconnected components. Such components may include routers, hubs, cabling, telecommunications controllers, key distribution centers, and technical control devices.	NIST Glossary
Network attached storage (NAS)	Dedicated storage devices that centralize storage of data. These storage devices generally do not provide traditional file, print, or application services. These devices could be physical or virtual.	ISACA Glossary
Network backbone	The main communication channel of a network that interconnects one or more network segments and provides a path for the exchange of data between devices. A backbone can span any geographic area.	FFIEC Developed for Supervisory Purposes
Network diagram	A network diagram (also called a network map or network topology) is a visual representation of nodes and connections in a computer network.	FFIEC Developed for Supervisory Purposes
Network operations center (NOC)	The central location or department responsible for monitoring the health and performance of the network, including analyzing and maintaining network traffic, telecommunications, and network disruptions.	FFIEC Developed for Supervisory Purposes

Term	Definition	Source
Network performance	Refers to the speed and response time of a network.	FFIEC Developed for Supervisory Purposes
Node	Point at which terminals are given access to a network.	ISACA Glossary
Non-production environment	Systems (e.g., applications, infrastructure, networks, operating systems) that are not used for production purposes. For example, systems that are used as development or test environments for new software or technologies or changes to existing software or technologies.	FFIEC Developed for Supervisory Purposes
O		
Open source software	Open source software is software that can be accessed, used, modified, and shared by anyone.	NIST S 6106.01
Operating system (OS)	The software “master control application” that runs the computer. It is the first program loaded when the computer is turned on, and its main component, the kernel, resides in memory at all times. The operating system sets the standards for all application programs (such as the Web server) that run in the computer. The applications communicate with the operating system for most user interface and file management operations.	NIST Glossary
Operational controls	The day-to-day procedures and mechanisms used to protect operational systems and software. Operational controls affect the system and software environment.	NIST Glossary
Operational level agreement (OLA)	An internal agreement covering the delivery of services that support the IT organization in its delivery of services.	ISACA Glossary
Operational resilience	The ability of systems to resist, absorb, and recover from or adapt to an adverse occurrence during operation that may cause harm, destruction, or loss of ability to perform mission-related functions.	NIST Glossary
	The ability of an entity’s personnel, systems, telecommunications networks, activities, or processes to resist, absorb, and recover from or adapt to an incident that may cause harm, destruction, or loss of ability to perform mission-related functions.	FFIEC Adapted for Supervisory Purposes
Operations	The performance of activities comprising methods, principles, processes, procedures, and services that support business functions.	FFIEC Developed for Supervisory Purposes
Operations management	The process of overseeing the methods, activities, or performance of practical work, and application of principles, processes, procedures, and services of an entity, utilizing business resources.	FFIEC Developed for Supervisory Purposes
Out-of-band	Communication between parties utilizing a means or method that differs from the current method of communication.	NIST Glossary
P		
Packet	A logical unit of network communications produced by the transport layer.	NIST Glossary
Packet sniffers	Software that monitors network traffic on wired or wireless networks and captures packets.	NIST Glossary

Term	Definition	Source
Patch	Fixes to software programming errors and vulnerabilities.	ISACA Glossary
Patch management	The systematic notification, identification, deployment, installation, and verification of operating system and application software code revisions. These revisions are known as patches, hot fixes, and service packs.	NIST Glossary
Penetration testing	A test methodology in which assessors, using all available documentation (e.g., system design, source code, manuals) and working under specific constraints, attempt to circumvent the security features of an information system.	NIST Glossary
Physical access controls	Mitigations that protect an entity's facilities, physical assets, and technology assets.	NIST 800-53 Rev. 5
Platform	A computer or hardware device and/or associated operating system, or a virtual environment, on which software can be installed or run.	NIST Glossary
Platform as a service (PaaS)	The capability provided to the consumer is to deploy onto the cloud infrastructure consumer-created or acquired applications created using programming languages, libraries, services, and tools supported by the provider. The consumer does not manage or control the underlying cloud infrastructure including network, servers, operating systems, or storage, but has control over the deployed applications and possibly configuration settings for the application-hosting environment.	NIST Glossary
Policies	Statements, rules or assertions that specify the correct or expected behavior of an entity.	NIST Glossary
Port	The entry or exit point from a computer for connecting communications or peripheral devices.	NIST Glossary
Portability	1) The ability to transfer data from one system to another without being required to recreate or reenter data descriptions or to modify significantly the application being transported. 2) The ability of software or of a system to run on more than one type or size of computer under more than one operating system.	ATIS Telecom Glossary
Power sag (aka voltage sag)	A brief reduction in voltage, often caused by a short circuit, overload or loose connection.	FFIEC Developed for Supervisory Purposes
Primary working memory	For the purposes of this booklet, primary working memory refers to the temporary storage or memory needed to run software applications that is shipped with the CPU and is generally supplemented by additional data storage (i.e., long-term storage).	NIST Glossary
Private cloud	The cloud infrastructure is provisioned for exclusive use by a single entity with multiple business units. The private cloud infrastructure may be owned, managed, and operated by the entity, a third party, or some combination of them, and it may exist on or off premises.	NIST Glossary
Problem	In IT, the unknown underlying cause of one or more incidents.	ISACA Glossary
Procedures	A document containing a detailed description of the steps necessary to perform specific operations in conformance with applicable standards. Procedures are defined as part of processes.	ISACA Glossary

Term	Definition	Source
Process improvement	Process improvement includes the actions taken to improve the quality of the organization's processes aligned with the business needs and the needs of other concerned parties.	ISO/IEC 33001:2015(en)
Promiscuous mode	A configuration setting for a network interface card that causes it to accept all incoming packets that it sees, regardless of their intended destinations.	NIST SP 800-94
Protocol	A set of rules (i.e., formats and procedures) to implement and control some type of association (e.g., communication) between systems.	NIST Glossary
Provisioning	The activity of obtaining the equipment and resources you need for a particular activity.	Cambridge Dictionary
	The activity of obtaining, modifying, and making available the equipment, resources, software, or services a user needs to carry out a particular activity.	FFIEC Adapted for Supervisory Purposes
Public cloud	The public cloud infrastructure is provisioned for open use by the general public. The public cloud infrastructure may be owned, managed, and operated by a business, academic, government organization, or some combination of them. It exists on the premises of the cloud service provider.	NIST Glossary
Q		
Query	In databases, a request for data or information from a table or combination of tables.	FFIEC Developed for Supervisory Purposes
R		
Rate limiting	A process used to control the rate of network traffic (e.g., incoming and outgoing). Its purpose is to prevent a failure of service (e.g., from a DOS attack or system overload).	FFIEC Developed for Supervisory Purposes
Release	A collection of new and/or changed configuration items, which are tested and introduced into a production environment together.	NIST Glossary
Remote access	Access to an organizational information system by a user (or an information system) communicating through an external, non-organization-controlled network (e.g., the Internet).	NIST Glossary
Replication	Involves the use of redundant software or hardware elements to provide availability and fault-tolerant capabilities. In a database context, replication involves the sharing of data between databases to reduce workload among database servers, thereby improving client performance while maintaining consistency among all systems.	ISACA Glossary
Report	A detailed account or statement. For the purposes of IT, the report provides analysis that supports informed decision-making.	Merriam-Webster
Resilience	The ability to prepare for and adapt to changing conditions and withstand and recover rapidly from disruptions. Resilience includes the ability to withstand and recover from deliberate attacks, accidents, or naturally occurring threats or incidents.	NIST Glossary
Role-based access	A model for controlling access to resources where permitted actions on resources are identified with roles rather than with individual subject identities.	NIST Glossary